

Comparison Summary

- Task 2 deliverable (Poorvi Bagga)

SMS/Email One-Time Password (OTP)

How does it work?

OTP, or One-Time Password, is a method of authenticating users using a special password that is used only once. In this user-authentication mode, when a user attempts to access the system, a password is sent to them. This password is valid for a short time. As this password is set to expire soon, users are protected against intruders even if other passwords have been compromised.

Advantage

- Enhancements in security reduction of the chance of password duplication and phishing attacks.
- Flexible delivery options using SMS, email, and authenticator applications.
- Enforces regulatory compliance requirements.
- It can be effortlessly integrated with multi-factor authentication systems.

Disadvantage

- Delays in delivery or interception are possible in SMS and email OTP systems.
- There is a chance the user will be unable to access the OTPs on their devices if they are lost or go out of range.
- Even phishing attacks may succeed in extracting OTPs from users. If not done efficiently, repeated OTP entry could degrade the user experience.

Used resource: <https://www.loginradius.com/blog/identity/what-is-otp-authentication>

TOTP Authentication

How does it work?

The Time-Based One-Time Password (TOTP) protocol provides a unique code that is subject to change. Codes are retrieved through applications such as Google Authenticator, Microsoft Authenticator, Authy, and LoginRadius Authenticator.

Advantage

- TOTP is time-bound and ever-changing, which limits a stranger's ability to gain access.
- Also, since these codes are not created through the internet or network but instead created on the user's device, they are more reliable and more secure than the codes sent through SMS and email.
- Authenticator apps that support TOTP are typically used offline and are compatible with multiple platforms.

- TOTP benefits from being based on an industry standard and is therefore integrable with various multi-factor solutions.

Disadvantage

- TOTP requires a synchronized time source for the authenticator app and the server to work correctly. Otherwise, a failed attempt will occur.
- The user may be unable to access their device if it is lost or damaged, or if they uninstalled the app without backing it up securely
- The user is needed to enter code through this app during login, thus adding more steps compared to a more streamlined option like a push notification.

Used resource:

<https://www.loginradius.com/blog/engineering/what-is-totp-authentication>

Push Notification Approval

How does it work?

Push notification authentication involves a real-time notification sent to the user's registered mobile device when someone tries to log in. The notification shows the user all the login details, such as device, time, and location, and the user can approve or reject with a single tap on their user device. If the user allows the alert, access is granted; if the user denies it, the request is blocked.

Advantage

- Enhances security by requiring users to confirm logins from trusted devices, making unauthorized access more difficult.
- It provides an end-to-end user experience that requires no physical code entry.
- Sends immediate alerts to users so they can take instant action upon seeing any unknown login attempts.
- Reduces the risk of phishing, since users are not entering codes that could be stolen.

Disadvantage

- Needs reliable Internet access along with an active mobile device to send mobile alerts.
- Additionally, if the mobile device is compromised, lost, or disconnected, the user may not be able to complete the authentication process.
- Users may unknowingly grant access to malevolent login attempts unless the information is thoroughly checked.

Used resource:

<https://www.loginradius.com/blog/identity/push-notification-authentication>

Hardware Security Tokens / Security Keys

How does it work?

Hardware security tokens, like YubiKey or Google Titan, are physical tokens that create a second authentication factor. At the time of login, the user plugs the token in via USB, NFC, or Bluetooth and turns it on. Avoids interception, ensuring only the owner of the token can be successfully authenticated.

Advantage

- Provides a very strong layer of security, especially against phishing and credential theft, because the cryptographic private key never leaves the hardware.
- Guards against account takeover better than many other 2FA methods, since attackers cannot generate the required cryptographic response remotely.
- Works across devices and services that support standards, enabling widespread adoption.

Disadvantage

- The user always needs a device. If lost, they may be locked out of your account.
- Also, there are some websites or services that don't support hardware keys at all.

Used resource:

<https://www.keepersecurity.com/blog/2023/05/09/what-is-a-hardware-security-key-and-how-does-it-work/>

Biometric 2FA (Fingerprint, Face ID, Iris, Voice)

How does it work?

Fingerprints, facial features, eye patterns, and similar information are used for user verification through the device's sensors.

Advantage

- Fast, convenient, and hard to copy.
- Reduces password reset operations, improving the end-user experience.

Disadvantage

- Concerns over privacy and biometric data are unchangeable and cannot be modified if compromised.

Used resources:

<https://medium.com/@lathusanlathusan40/biometric-authentication-on-android-secure-and-user-friendly-access-control-9f17e20eed24>